Security incident report

Section 1: Identify the network protocol involved in the incident

The protocol involved is HTTP (Hypertext Transfer Protocol), which works at the application layer. Web pages from yummyrecipesforme.com travel over HTTP, and the tcpdump log shows the browser using it to talk to the site. The same protocol carried the malicious file to the visitors' computers.

Section 2: Document the incident

Several customers wrote to the helpdesk saying that the website asked them to download and run a file to get free recipes. After that their computers became very slow. At the same time the website owner could not log in to their own admin account anymore.

To investigate I used a sandbox, so the company network was not at risk. I started tcpdump, opened the website, accepted the download and ran the file. The browser then sent me to a different site, greatrecipesforme.com.

The tcpdump log tells the same story. First the browser asks for the IP address of yummyrecipesforme.com and connects to it over HTTP. After the file is executed, the traffic changes: the browser asks for a new IP address, the one of greatrecipesforme.com, and the connection is redirected there.

A senior analyst read the source code of the website and of the downloaded file. The attacker had added code to the website that offered a fake browser update, which was the malicious file. Since the owner was locked out of the admin account, we think the attacker got in with a brute force attack, changed the admin password, and then edited the site.

Section 3: Recommend one or more remediations for brute force attacks

First, I would stop people from reusing old passwords, and the default one above all. The attacker got in because a weak or default password was still working, so a new password must always be different from the previous ones.

Second, I would limit the failed login attempts and lock the account for a while after a few mistakes. A brute force attack needs thousands of tries, so this makes it very slow.

Third, I would add two-factor authentication (2FA). Even if someone guesses the password, they would also need the one-time code sent to the owner's phone or email, so the password alone is useless. I would also ask for password changes on a regular schedule.